M1 – REQUIREMENTS SPECIFICATION

SECURE UNIVERSITY e-STORE

University	Al al-Bayt University
Course	Secure Electronic Commerce (906425)
Student Name	Khaled Ayman Abu Jamous
Group Number	G16
Project Type	Individual Project
Instructor	Dr. Mohammad Ahmad Mohammad Al-Shanwan
Academic Semester	First Semester 2026/2027

1. Project Overview

The Secure University e-Store is an online store for the university. Students and staff buy textbooks, lab kits and university merchandise, and approved student vendors sell their own items (a B2C store with a C2C marketplace). The store provides a product catalogue, shopping cart, checkout, payment through a simulated payment gateway (PayLab), order tracking, reviews and an administration area.

The system serves four roles: Customer, Vendor, Store Administrator and Security Auditor. Every permission is enforced on the server for each request, because hiding a button in the interface is not authorisation. The platform protects user accounts, secures the payment flow, keeps internal services unreachable from outside, and records important security and administrative events.

Technology stack: Python 3.12 with Django, PostgreSQL 16, a documented REST API (OpenAPI 3), and Docker Compose. The services are a reverse proxy with HTTPS, the web application, the PayLab payment service, an image fetcher, an internal-only service (the SSRF target) and a local mail catcher (Mailpit). A separate LAB build contains deliberately vulnerable features and runs on localhost only.

2. Project Objectives

- Provide a secure and user-friendly online shopping platform.
- Let customers browse products, manage carts and place orders whose totals are computed by the server.
- Let approved vendors manage their own products only.
- Integrate payments through the PayLab hosted page and confirm them only by a verified signed webhook.
- Protect sensitive data: password hashes, 2FA secrets, addresses and payment tokens.
- Enforce Role-Based Access Control (RBAC) and object-ownership checks on the server.
- Keep an append-only audit log and a security-event log that only the Security Auditor can read.
- Prevent and test common web vulnerabilities: XSS, CSRF, XXE, SSRF, API flaws and clickjacking.
- Provide a documented REST API (OpenAPI 3) that matches the implementation.
- Keep the secure build separate from the intentionally vulnerable LAB build.

3. Functional Requirements

FR01 – User Registration and Authentication

- The system shall allow users to register with a unique e-mail address and a password.
- The system shall store passwords only as bcrypt or Argon2 hashes.
- The system shall allow users to log in and log out; logout destroys the session on the server.
- The system shall rate-limit failed logins and apply a temporary lockout, and shall return the same generic message for a wrong e-mail and a wrong password.
- The system shall require TOTP two-factor authentication for vendors and administrators.
- The system shall provide password reset by e-mail with single-use tokens that expire within 15 minutes.
- The system shall use session cookies with HttpOnly, Secure and SameSite attributes, issue a new session ID after login, and apply idle and absolute session timeouts.

FR02 – Product Catalogue

- The system shall allow browsing, searching and filtering of products (public access).
- The system shall display product details, prices, descriptions, images and customer reviews.

FR03 – Shopping Cart and Checkout

- The system shall allow customers to add products, change quantities and remove items.
- The system shall let customers provide or select a shipping address and shall show an order summary.

- The system shall calculate the order total, discounts and unit prices on the server from the database. Totals, prices or states sent by the client shall be ignored, and negative or zero quantities shall be refused.

FR04 – Secure Payment Integration

- The system shall create the order in the state PENDING_PAYMENT and redirect the customer to the PayLab hosted payment page.
- The system shall never receive or store a card number; only the PayLab token and transaction data are stored.
- The system shall confirm payment only through a PayLab webhook signed with HMAC-SHA256 over the body and a timestamp.
- The system shall mark an order PAID only after verifying the signature, a timestamp within 5 minutes, a unique event ID (replay and duplicate protection) and the expected amount.
- A rejected webhook shall leave the order in PENDING_PAYMENT and shall be logged as a security event.

FR05 – Order Management and Tracking

- The system shall let customers view their own order history and the current status of each order.
- The system shall provide live order status updates over a WebSocket that requires an authenticated session, checks the Origin header and sends each customer only their own orders.

FR06 – Vendor Product Management

- The system shall let approved vendors create, edit and remove their own products.
- The system shall prevent a vendor from modifying products owned by another vendor, and shall restrict publishing to approved vendors.
- The system shall support image upload or fetching an image from a URL. The fetch runs in a separate Image Fetcher that accepts only https and an allow-list of hosts, refuses loopback, private and link-local addresses, does not follow redirects, applies timeouts and size limits, and has no network route to the internal service.

FR07 – Bulk Catalogue Import

- The system shall let vendors import a catalogue from an XML or CSV file.
- The XML parser shall have DTDs and external entities disabled; the content type, file size and schema shall be validated, and invalid or unauthorised imports shall be rejected.

FR08 – Product Reviews

- Only customers who purchased a product may review it, with a rating from 1 to 5.
- Review text may use limited formatting and shall be sanitised with an allow-list library and output-encoded to prevent stored XSS.

FR09 – Coupons and Discounts

- The system shall let administrators create and manage coupons with a percentage, an expiry date and a maximum number of uses.
- The system shall validate and apply coupons on the server, and used_count shall never exceed max_uses.

FR10 – Administration and Security Auditing

- Store administrators shall manage users, vendor approval, categories, coupons and refunds.
- A refund shall require an administrator, a reason and an audit record, and the refunded amount shall never exceed the paid amount.

- Security auditors shall have read-only access to the security-event log, the admin audit log and CSP reports; no role may update or delete audit records.
- The system shall log failed logins, refused access, rejected webhooks, CSP reports and administrator actions.

FR11 – REST API Documentation

- The system shall provide a REST API documented in openapi.yaml (OpenAPI 3) and used by the front end for all operations.
- Any endpoint not in the OpenAPI file shall not exist in the secure build: undocumented endpoints and methods return 404/405 and a wrong content type returns 415.
- Request bodies shall be bound to explicit allow-listed fields, so fields such as role, price or status cannot be mass-assigned; errors shall not expose stack traces or SQL.

FR12 – Project Reproducibility and Security Separation

- The project shall include a README that rebuilds the system on a clean machine, with a docker-compose.yml, SQL scripts, a seed script, a reset script and a .env.example without secrets.
- The secure build and the LAB build shall run as separate Compose profiles, never on the same ports and never outside localhost.

4. User Roles and Permissions

4.1 Customer

A registered user who buys products.

Allowed actions	Restricted actions
• Register, log in and manage own profile and addresses. • Browse and search products; manage the cart. • Place orders and pay through PayLab. • View own orders and their live status. • Review products that were purchased.	• Cannot view another customer's orders or addresses (IDOR attempts are refused and logged). • Cannot change a price, discount or order total. • Cannot review an item that was not purchased. • Cannot access product management, administration or audit logs.

4.2 Vendor

An approved user who sells their own products.

Allowed actions	Restricted actions
• Manage own products, prices, stock and images. • Import a catalogue from XML or CSV. • View orders that contain their own products. • Use TOTP two-factor authentication to log in.	• Cannot edit or remove another vendor's products. • Cannot see customers' payment data. • Cannot change an order or payment status. • Cannot publish products before vendor approval. • Cannot access audit logs or administration.

4.3 Store Administrator

Manages the platform and its authorised operations.

Allowed actions	Restricted actions
• Approve vendors; manage users and categories. • Create and manage coupons. • Issue refunds through the documented workflow (reason and audit record required). • Use TOTP two-factor authentication to log in.	• Cannot mark an order PAID without a verified payment. • Cannot edit or delete audit records. • Every administrative action is recorded in the audit log.

4.4 Security Auditor

Monitors the system and reviews security records.

Allowed actions	Restricted actions
• Read the security-event log, the admin audit log and CSP reports. • Review failed logins, refused access and rejected webhooks.	• Read-only: cannot change any order, product, user or payment data. • Cannot modify or delete audit logs. • Cannot perform administrative operations.

5. Use Cases

5.1 Customer

Use case	Description
Register Account	Create a customer account with a unique e-mail and a password.
Login	Authenticate with credentials; failed attempts are rate-limited.
Browse / Search Products	View, search and filter the catalogue.
Manage Cart	Add, update or remove cart items.
Checkout	Choose a shipping address and coupon; the server computes the total and creates the order.
Make Payment	Pay on the PayLab hosted page; the order becomes PAID only after the verified webhook.
Track Order	View order history and the live status over WebSocket.
Submit Review	Rate and review a purchased product.

5.2 Vendor

Use case	Description
Login with 2FA	Authenticate with password and TOTP code.
Add / Edit / Remove Product	Manage own products only.
Upload or Fetch Image	Upload an image or fetch it from an allow-listed https URL.
Import Catalogue	Import products from an XML or CSV file.
View Own Product Orders	See orders that contain the vendor's products.

5.3 Store Administrator

Use case	Description
Login with 2FA	Authenticate with password and TOTP code.
Manage Users and Vendors	Manage accounts and approve vendors.
Manage Categories and Coupons	Create and maintain categories and coupons.
Issue Refund	Refund a paid order with a reason; the action is audited.

5.4 Security Auditor

Use case	Description
View Security Events	Review failed logins, refused access, rejected webhooks and CSP reports.
View Admin Audit Log	Review administrator actions (read-only).

Use case	Description
Monitor Suspicious Activity	Identify repeated failures and suspicious sources.

6. Business Rules

Rule	Description
BR01 Vendor Approval	Only approved vendors may publish products.
BR02 Product Price	Product prices must be greater than zero (CHECK).
BR03 Product Stock	Stock must be zero or greater (CHECK).
BR04 Product Ownership	A vendor may modify or remove only their own products.
BR05 Order Quantity	The quantity of each ordered item must be greater than zero.
BR06 Order Total	The server computes the total; the unit price is copied from the product into the order item at checkout.
BR07 Payment Data	No card number is stored; only the PayLab token and transaction data.
BR08 Payment Verification	An order becomes PAID only after the payment webhook is verified.
BR09 Webhook Security	Verify HMAC-SHA256, a timestamp within 5 minutes, a unique event ID (event_id is UNIQUE) and the expected order and amount.
BR10 Payment Redirect	A browser redirect back from PayLab proves nothing and never changes an order status.
BR11 Product Reviews	Only customers who purchased the product may review it.
BR12 Review Rating	Ratings must be from 1 to 5.
BR13 Review Content	Review text is sanitised with an allow-list library before it is stored or shown.
BR14 Coupon Usage	Coupons are validated on the server by expiry date and maximum uses; used_count never exceeds max_uses.
BR15 Refund Authorisation	A refund needs an administrator, a reason and an audit record; the refunded amount never exceeds the paid amount.
BR16 Audit Log Protection	The audit log is append-only; no role may update or delete records.
BR17 RBAC	Role permissions and object ownership are enforced on the server for every request; the role is never accepted from the client.
BR18 Login Protection	Failed logins are rate-limited with a temporary lockout; the error message is the same for a wrong e-mail and a wrong password.
BR19 Reset Tokens	Password reset tokens are single-use and expire within 15 minutes.
BR20 Two-Factor Authentication	Vendors and administrators must pass TOTP verification at login.
BR21 Image Fetching	Image URLs are fetched only over https from allow-listed hosts, without redirects, and never from loopback, private or link-local addresses.
BR22 Catalogue Import	Imported XML must not use DTDs or external entities; file type, size and schema are validated.
BR23 Mass Assignment	Fields such as role, price, total and status are never accepted from request bodies.

7. Order State Machine

7.1 Order states

- **CREATED:** the order has been created from the cart.
- **PENDING_PAYMENT:** the order is waiting for payment confirmation from PayLab.

- **PAID:** the payment was confirmed by a verified webhook.
- **SHIPPED:** the order has been shipped.
- **DELIVERED:** the order has been delivered.
- **CANCELLED:** the order was cancelled before payment.
- **REFUNDED:** a paid order was refunded through the authorised refund workflow.

7.2 Normal workflow

CREATED > PENDING_PAYMENT > PAID > SHIPPED > DELIVERED

CANCELLED and REFUNDED are side states.

7.3 Permitted transitions

From	To	Triggered by	Condition
(new)	CREATED	Server, on checkout	Cart is not empty, quantities are above zero, total recomputed from the database.
CREATED	PENDING_PAYMENT	Server	Customer is redirected to the PayLab hosted page.
PENDING_PAYMENT	PAID	Server, on verified webhook	Valid HMAC-SHA256 signature, timestamp within 5 minutes, unused event ID, amount equals the order total.
PAID	SHIPPED	Server, after an authorised fulfilment update by a Store Administrator	Order is PAID; the action is written to the audit log.
SHIPPED	DELIVERED	Server, same as above	Order is SHIPPED; the action is audited.
CREATED, PENDING_PAYMENT	CANCELLED	Customer (own order) or server on payment timeout	No verified payment exists for the order.
PAID, SHIPPED, DELIVERED	REFUNDED	Store Administrator through the refund workflow	Reason and audit record are required; refunded amount does not exceed the paid amount.

- Only the server moves an order between states; any transition not listed above is rejected.
- A browser redirect from PayLab never changes an order status; only the verified webhook can set PAID.
- Vendors and security auditors cannot change an order or payment status.

8. Security Requirements

Each mandatory security requirement of the project is applied to this store as follows.

Requirement	How it applies to the e-Store
SR01 Authentication	bcrypt/Argon2 hashes, rate-limited logins with lockout, TOTP 2FA for vendors and administrators, single-use reset tokens valid for 15 minutes, generic login errors.
SR02 Sessions and cookies	HttpOnly, Secure and SameSite cookies, new session ID after login, idle and absolute timeouts, server-side logout.
SR03 Authorisation	RBAC for every endpoint, ownership checks against IDOR (orders, addresses, products), role never taken from the client.
SR04 XSS	Template auto-escaping, no innerHTML with untrusted data, allow-list sanitiser for reviews; stored, reflected and DOM XSS are demonstrated in the LAB and fixed.
SR05 CSP	Nonce-based CSP with object-src 'none', base-uri 'none' and frame-ancestors 'none'; report-only first, then enforced; reports logged for the auditor.

Requirement	How it applies to the e-Store
SR06 CSRF	Anti-CSRF tokens, SameSite cookies and Origin/Referer checks on every state-changing request; no state change by GET.
SR07 XXE	Catalogue import parser with DTDs and external entities disabled; content type, size and schema validated.
SR08 SSRF	Image Fetcher with https-only, host allow-list, address checks, no redirects, timeouts, size limits and no network route to the internal service.
SR09 API security	OpenAPI matches the implementation; 404/405 for unknown endpoints; 415 for wrong content types; allow-listed request fields; schema validation; rate limiting; no stack traces.
SR10 Clickjacking	X-Frame-Options DENY and CSP frame-ancestors on all pages; re-confirmation for placing an order, changing e-mail and deleting an account.
SR11 Payment integrity	Server-side prices and totals, order state machine, verified PayLab webhook, no card data stored (reduces PCI DSS scope).
SR12 Third-party scripts	Self-hosted scripts or Subresource Integrity, CSP script sources, dependency audit before every milestone tag.
SR13 CORS and WebSocket	CORS allows only the store's exact origin; the WebSocket needs a session, checks Origin and sends each customer only their own orders.
SR14 Transport, headers, secrets, logging	HTTPS with HSTS, X-Content-Type-Options, Referrer-Policy and Permissions-Policy; secrets only in environment variables (.env.example committed); append-only audit log; unified test log.

Security events shall record the event type, source IP, actor, outcome and timestamp.

9. Expected Outcome

The expected outcome is a working university e-commerce platform that supports customer shopping, vendor product management, online payment through PayLab, order tracking, administration and security auditing. The deliverables include the database design, the architecture and data-flow diagrams, the OpenAPI specification, the implementation, the attack proofs-of-concept in the LAB build with their fixes, and the security test results required by the project milestones.

End of M1 Requirements Specification